

Warsaw, the 30th
of November
2023

Decision

DKN.5131.13.2022

Pursuant to Article 104 § 1 of the Act of June 14, 1960, the Code of Administrative Procedure (Journal of Laws of 2023, item 775) in connection with Articles 7, 60, 101, and 103 of the Act of May 10, 2018, on the Protection of Personal Data (Journal of Laws of 2019, item 1781), Article 57(1)(a) and (h) and Article 58(2)(i), as well as Article 83(1) – (2) and Article 83(4)(a) in connection with Article 32(1) and (2) of the Regulation of the European Parliament and of the Council (EU) 2016/679 of April 27, 2016, on the protection of natural persons with regard to the processing of personal data and on the free movement of such data, and repealing Directive 95/46/EC (General Data Protection Regulation) (OJ EU L 119 of 4.05.2016, p. 1, OJ EU L 127 of 23.05.2018, p. 2, and OJ EU L 74 of 4.03.2021, p. 35), after conducting an ex officio administrative proceeding regarding the violation of personal data protection regulations by S7Health Sp. z o.o. based in W. at ul. (...), the President of the Personal Data Protection Office finds that S7Health Sp. z o.o. based in W. has violated the provisions of Articles 32(1) and (2) of the Regulation of the European Parliament and of the Council (EU) 2016/679 of April 27, 2016, on the protection of natural persons with regard to the processing of personal data and on the free movement of such data, and repealing Directive 95/46/EC (General Data Protection Regulation) (OJ EU L 119 of 4.05.2016, p. 1, OJ EU L 127 of 23.05.2018, p. 2, and OJ EU L 74 of 4.03.2021, p. 35), hereinafter referred to as the "Regulation 2016/679", consisting of the failure to implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk of data processing, including ensuring the ability to continuously maintain the availability and resilience of processing systems and services, as well as the ability to quickly restore the availability of personal data and access to it in the event of a physical or technical incident, taking into account the risks associated with processing resulting from the accidental or unlawful destruction or loss of personal data stored or otherwise processed in the IT system XXX and stored on servers that were destroyed, imposes on S7Health Sp. z o.o. based in W. an administrative fine in the amount of 117,900 PLN (in words: one hundred seventeen thousand nine hundred zlotys).

Justification

S7Health Sp. z o.o. based in W. at ul. (...) (hereinafter also referred to as the "Company" or "S7Health"), conducting business consisting of mediating in the provision of medical services, on March 22, 2021, reported to the President of the Personal Data Protection Office (hereinafter also referred to as the "President of UODO") a personal data breach consisting of the destruction of the server room due to a fire, which violated the availability attribute of personal data, for which S7Health was the administrator. The reported personal data breach was registered by the President of UODO under reference number DKN.5130.2892.2021. In connection with the submission of the personal data breach notification by letter dated February 17, 2022, the President of UODO requested the Company to provide explanations and submit evidence to confirm them, including regarding:

1. whether the Company had a backup copy of the data located in the server room that was destroyed due to the fire, and if so, whether the lost data was recovered and to what extent;
2. whether prior to the occurrence of the breach, the Company had developed and implemented a procedure for creating and testing backup copies of the systems covered by the breach; if so, please provide a copy of this procedure indicating the frequency of creating backup copies and the date of the last backup copy made prior to the reported breach;
3. whether the Company conducted a risk analysis and the impact of the lack of availability of data processed using the IT systems covered by the breach on the rights or freedoms of the individuals whose data are concerned.

In response, S7Health, by letter dated March 9, 2022, provided explanations informing that:

- it did not have a backup copy of the data located in the server room that was destroyed due to the fire,

- prior to the occurrence of the personal data breach, it did not have a developed and implemented procedure for creating and testing backup copies of the systems covered by the breach,
- it conducted a risk analysis, as evidence of which, as an attachment to the aforementioned letter, it presented the "Analysis (...) dated December 31, 2020. However, the "risk analysis" presented by the Company did not constitute "an analysis of the risk and impact of the lack of availability of data processed using the IT systems covered by the breach on the rights or freedoms of the individuals whose data are concerned," which the President of UODO requested the Company to provide.

In connection with the explanations submitted by S7Health, on March 15, 2022, the President of UODO initiated administrative proceedings regarding the possibility of violation by S7Health, as the data controller, of the obligations arising from Article 32(1) and (2) of Regulation 2016/679, in connection with the personal data breach reported to the President of the UODO. The administrative proceedings concerning the violation of personal data protection regulations have been registered under number DKN.5131.13.2022.

In response to the initiation of administrative proceedings, in a letter dated March 29, 2022, S7Health requested the presentation of evidence from documents, namely the "Policy (...)" – regarding the fact of developing, implementing, and adhering to appropriate personal data protection procedures, and the "Agreement (...)" regarding the fact of entrusting the processing of personal data to O. Furthermore, in a letter dated March 29, 2022, S7Health requested the dismissal of the proceedings as entirely moot, explaining that the incident was solely of an incidental nature due to the lack of risk of violation of the rights or freedoms of natural persons and informing that "based on the information obtained by S7Health, the personal data stored on the servers that were destroyed in the fire were irretrievably lost, thus excluding the possibility of their unlawful use."

During the proceedings conducted in this matter, the President of the UODO, in letters dated June 22, 2022, November 9, 2022, December 27, 2022, and September 26, 2023, summoned S7Health to provide explanations and present evidence to confirm them. Subsequently, in a letter dated November 10, 2023, the President of the UODO informed S7Health about the collection of evidence sufficient to issue an administrative decision in this matter and about the right to express opinions regarding the evidence and materials collected during the proceedings and the submitted requests. Furthermore, it was informed that the party is entitled to review the case files and prepare notes, copies, or excerpts from them.

The party exercised the above rights by reviewing the files on November 21, 2023, and in a letter dated November 22, 2023, presented the party's position, in which it reiterated the arguments presented during the ongoing explanatory proceedings.

Based on the explanations and evidence confirming them submitted by S7Health in letters dated March 9, 2022, March 29, 2022, July 14, 2022, November 27, 2022, December 7, 2022, January 16, 2023, October 26, 2023, and November 22, 2023, as well as based on the report of the personal data breach made by S7Health on March 22, 2021, the supervisory authority established the following factual state.

1. On March 10, 2021, a fire occurred at the headquarters of O. in S., as a result of which the Company lost access to the IT system named XXX, used for managing customer contacts and processing personal data (lack of access to the system and lack of access to personal data) and lost documents containing data, including invoices and referrals for occupational medicine of employees of entities that collaborated with the Company, stored in that system. The servers were completely destroyed, with no possibility of recovering the lost data. The approximate number of individuals potentially affected by the breach was estimated by the Company to be around 14,000; the category of individuals indicated by the Company includes users of the XXX system and patients, as well as a category indicated as "new users and previous ones, from the period between March 1, 2020, and March 10, 2021 – individuals registering in the XXX system," and the scope of personal data that was breached includes: surnames, first names, addresses of residence or stay, PESEL identification

numbers, email addresses, and phone numbers. The Company characterized the nature of the personal data breach as a breach of data availability, where the following information was presented: "lack of possibility to use the data upon request, within the established time by a person authorized to do so." As possible consequences of the personal data breach for the individuals concerned, it indicated the loss of control over their personal data. Furthermore, on March 22, 2021, it notified individuals (in electronic form) and in the form of a communication available on the website about the personal data breach concerning approximately 14,000 individuals.

2. On May 25, 2018, S7Health entered into a data processing entrustment agreement with O. The subject of the agreement was the storage of personal data on the servers that were destroyed. Under the agreement, S7Health was responsible, among other things, for creating backup copies necessary to secure personal data, particularly before the termination or expiration of services and before proceeding with operations to delete, update, or reinstall the service.

3. On November 17, 2010, S7Health entered into an "Agreement (...)" with P. based in S. (hereinafter referred to as "P"). Under the above agreement, S7Health commissioned P. to provide medical services to its clients (individuals whose data are concerned), to whom it offered subscription-based medical care. P., in order to provide the medical service, received from S7Health by the 25th of each month an update – a list of clients (individuals whose data are concerned) entitled to use medical services within selected packages.

4. On March 9, 2021, that is, on the day preceding the occurrence of the personal data breach, S7Health submitted an update of the list of clients (individuals whose data are concerned) to P.

5. In the course of its professional activities, S7Health entered into agreements with individuals whose data are concerned and with the employers of those individuals for the provision of health services performed by P. As indicated in the documents attached to the letter.

****Companies from January 16, 2023, templates of contracts for individual and corporate clients (pages 149 and 151)****

S7Health issued to the data subjects a "patient card" within 30 days from the selection and payment of the medical service package. Until the patient card was received, the data subject could use medical services with prior telephone registration based on an entry in the IT system. As S7Health explained, "using the services provided by S7 requires prior payment via transfer. Despite the circumstances of data loss on the server, S7 has data on the bank account and email inboxes. In case of any doubts, it was possible to check and verify who paid for a given service. Additionally, S7Health had customer databases in email inboxes, as an updated list of clients was sent to Mr. P. every month." Furthermore, S7Health explained that the breach "particularly hindered the restoration of settlements with clients in the XXX system and made it impossible to issue duplicate invoices, and that the breach did not prevent the recovery of data upon a one-time request from the client – based on the payment history visible on the bank account and electronic correspondence, additionally in connection with the possibility of consulting the matter with the accounting office." At the same time, it indicated that it was impossible to provide an exact number of individuals affected by the breach. The company irrevocably lost documents containing data, including invoices and referrals for occupational medicine for employees of companies cooperating with S7Health.

6. S7Health collected and processed personal data of the data subjects on servers that were burned, for the purpose of concluding and executing the contract between S7Health and the data subject and the medical operator Mr. P, consisting of providing medical services to these individuals. At the same time, considering the Company's explanations that the breach "particularly hindered the restoration of settlements with clients in the XXX system," it should be stated that within this purpose, the Company also made settlements with clients. As indicated in the contract template provided by the Company "S7Health medical care for individual clients" – due to medical care, the data subject was obliged to pay S7Health an annual lump sum fee. The fee was payable in installments, with the first installment due upon signing the contract, and subsequent installments no later than the 20th day of the month preceding the month for which they are due. After one year, the contract transformed into an

indefinite-term contract, and the annual lump sum fee was replaced by monthly fees. Upon determining that the payment for the selected medical service package was not received by the required deadline, S7Health could temporarily invalidate the patient card, starting from the first day of the period for which the fee was to apply. After settling the dues, the possibility of using medical services commenced from the next month following the month in which S7Health recorded the payment of overdue fees, as well as timely payments. Additionally, in the context of achieving the above processing purpose, the Company at least through the XXX system forwarded referrals for occupational medicine from the employer to Mr. P. for employees who are data subjects affected by the breach and provided Mr. P. with an updated list of clients. The legal basis for processing data for this purpose was indicated by the Company as Article 6(1)(b) of Regulation 2016/679, and the data retention period was indicated as "until the termination of the contract and its settlement with the client."

Furthermore, the Company processed personal data of the data subjects by storing it on the server that was burned, for the purpose of archiving documents in fulfillment of its legal obligation. The legal basis for such processing was indicated by S7Health as Article 6(1)(c) of Regulation 2016/679 in connection with the obligation to retain data under Article 86 § 1 of the Act of August 29, 1997, the Tax Ordinance, and Article 74 of the Act of September 29, 1994, on Accounting. The retention period was indicated by the administrator as "5 years from January 1 of the year following the year in which the contract was terminated."

7. The number of individuals affected by the breach is approximately 14,000 individuals collectively referred to as users of the XXX system, including about 500 individuals whose documents containing data – including invoices and "referrals for occupational medicine for employees of companies cooperating with S7Health" were destroyed. At the same time, the President of the UODO did not accept the credibility of the explanations provided by S7Health in the letter dated January 16, 2023 (page 134) and did not give them evidentiary value, stating that "the number of individuals affected by the breach is not 1,400 but about 500, which we determined based on data from bank accounts and email messages," considering them not only as not resulting from the collected evidence but also as contradictory to it. Furthermore, the above explanations do not correspond with the Company's other explanations regarding the number of individuals affected by the breach of personal data protection. It should also be emphasized that the Company evaded providing specific answers aimed at determining the number and categories of individuals affected by the breach. In light of the above, it should be clarified that the Company informed the President of the UODO in the data breach notification form that the breach of personal data protection concerns approximately 14,000 individuals. The President of the UODO had no grounds to deny the credibility of the information contained in the aforementioned form, as, unlike the later explanations from the Company, they were logical, mutually complementary, and took into account the principles of life experience. At the same time, the Company in the notification form...

****Data Protection Breach Notification****

The notification regarding the breach of personal data indicated that 14,000 individuals were informed of the breach, as evidenced by the content of this notification (page 6). The content of the notification corresponding with the content of the personal data breach report indicates that the Company notified all users. Furthermore, it should be emphasized that, as stated in the letter dated November 27, 2022, the number of 500 individuals affected by the breach pertained solely to one category of individuals, namely those identified in the notification of the personal data breach as individuals whose documents containing data, including invoices and referrals for occupational medicine of employees from companies cooperating with S7Health, were destroyed. Thus, S7Health incorrectly related this number of individuals to all categories of persons affected by the breach. Additionally, in a letter dated December 27, 2022, the President of the Personal Data Protection Office (UODO) requested the Company to specify the number of individuals affected by the breach whose "data, in accordance with Article 86 § 1 of the Tax Ordinance and Article 74 of the Accounting Act," S7Health retained, in line with the explanations contained in the letter dated November 27, 2022. In response, the Company, in a

letter dated January 16, 2023, stated that "it is impossible to specify the exact number of individuals affected by the breach." At the same time, in this letter, it reiterated that "the number of individuals affected by the breach is not 1,400, but approximately 500, which we determined based on data from bank accounts and emails" (page 134). Such presented claims are mutually contradictory, devoid of logical reasoning, and inconsistent with the gathered evidence. The Company also did not provide any evidence regarding the aforementioned circumstance.

The President of UODO therefore has no doubt that due to the destruction of servers and the irreversible loss of the database, including personal data, and the XXX system, the Company lost the personal data of all users, not just specific categories of individuals, namely data concerning approximately 14,000 individuals, which is consistent with the number of individuals indicated in the personal data breach report. In light of the above, the President of UODO determined that the breach of personal data affected approximately 14,000 individuals collectively referred to as users of the XXX system, including 500 individuals "whose documents containing data – including invoices and referrals for occupational medicine of employees from companies cooperating with S7Health" were destroyed. At this point, it should be clarified that the President of UODO, in assessing the severity of the breach, referred to the aforementioned 500 individuals, indicating that this is already a very large number of individuals whose personal data breach is concerned.

8. S7Health did not have a backup copy of the data located in the server room, which was destroyed due to a fire, and prior to the occurrence of the breach, it did not have a developed and implemented procedure for creating and testing backups of the systems affected by the breach.

9. S7Health did not conduct and did not present, at the request of the President of UODO, a risk analysis regarding the impact of the lack of availability of data processed using the IT systems affected by the breach on the rights or freedoms of the individuals whose data is concerned.

10. After the personal data breach, S7Health continued to process personal data for the same purposes and for the same categories of individuals using IT systems. To reduce the likelihood of a similar personal data breach (concerning the attribute of availability) occurring in the future, S7Health began using the services of another server provider (main server) and conducts periodic backups of files on another server (located in a different location). Additionally, S7Health hired a specialist in the field of personal data protection, whose task will be to ensure the continuous development of security measures in the area of personal data processing.

11. S7Health had in place a "Policy (...), the content of which is attached as Appendix No. 2 to the letter from S7Health dated March 29, 2022" (hereinafter referred to as the "Security Policy").

12. S7Health conducted a risk analysis "for resources processing personal data," the content of which is attached to the letter from S7Health dated March 9, 2022, based on the "methodology for conducting a risk assessment for resources processing personal data," the content of which is attached to the letter from S7Health dated November 27, 2022.

In this factual state, after reviewing all the evidence gathered in the case, the President of the Personal Data Protection Office considered the following:

According to Article 34 of the Act of May 10, 2018, on the Protection of Personal Data (Journal of Laws of 2019, item 1781) - hereinafter referred to as the Act of May 10, 2018, the President of UODO is the competent authority in matters of data protection and the supervisory authority within the meaning of Regulation 2016/679. Pursuant to Article 57(1)(a) and (h) of Regulation 2016/679, without prejudice to other tasks specified under this regulation, each supervisory authority in its territory monitors and enforces the application of this regulation and conducts proceedings regarding breaches of this regulation, including based on information received from another supervisory authority or another public authority. The content of Article 32(1) of Regulation 2016/679 indicates that the controller is obliged to implement technical and organizational measures that correspond to the risk of infringement of the rights and freedoms of individuals with varying probabilities of occurrence and severity of the threat. The provision specifies that in deciding on technical and organizational measures, one must

take into account the state of technical knowledge, the cost of implementation, the nature, scope, context, and purposes of processing, as well as the risk of infringement of the rights or freedoms of individuals with varying probabilities of occurrence and severity. From the cited provision, it follows that the determination of appropriate technical measures...

i organizational processes is a two-step process.

1. First and foremost, it is essential to determine the level of risk associated with the processing of personal data, taking into account the criteria specified in Article 32(1) of Regulation 2016/679. Subsequently, it is necessary to establish what technical and organizational measures will be appropriate to ensure a level of security corresponding to that risk. These findings, where appropriate, should include measures such as pseudonymization and encryption of personal data, the ability to ensure confidentiality, integrity, availability, and resilience of processing systems and services on an ongoing basis, the ability to quickly restore the availability of personal data and access to it in the event of a physical or technical incident, as well as regular testing, measuring, and assessing the effectiveness of technical and organizational measures intended to ensure the security of processing. According to Article 32(2) of Regulation 2016/679, when assessing whether the level of security is appropriate, the controller takes into account, in particular, the risks associated with processing, especially those arising from accidental or unlawful destruction, loss, alteration, unauthorized disclosure, or unauthorized access to personal data transmitted, stored, or otherwise processed.

2. Recital 76 of Regulation 2016/679 states that "the likelihood and severity of the risk to the rights or freedoms of the data subject should be assessed by reference to the nature, scope, context, and purposes of the processing of personal data. The risk should be assessed on the basis of an objective evaluation, within which it is determined whether the processing operations involve a risk or a high risk."

3. Recital 75 of Regulation 2016/679 indicates that "the risk of infringement of the rights or freedoms of individuals, with varying likelihood and severity of threats, may arise from the processing of personal data that could lead to physical harm or material or non-material damage, in particular: if the data subjects may be deprived of their rights and freedoms or the ability to control their personal data."

4. First and foremost, it should be noted that S7Health reported a personal data breach as the data controller whose data was breached and defined itself as the controller in internal procedures. Furthermore, while collecting personal data in the information clause, it indicated that it is the controller and also entered into data processing agreements where it acted as the controller. It should be emphasized that the status of the controller depends on the factual circumstances and is assigned to the entity that determines the purposes and means of processing personal data, in accordance with the definition of the data controller expressed in Article 4(7) of Regulation 2016/679, where "controller" means the natural or legal person, public authority, agency, or other body that alone or jointly with others determines the purposes and means of the processing of personal data.

5. In the circumstances of the case at hand, it was evident that S7Health is the controller of the data that was breached, as the Company, while collecting personal data, set the purposes and decided to process personal data for its own purposes established within the factual framework, as well as decided on the means of processing that data. At the same time, it should be emphasized that the provision of Article 32 of Regulation 2016/679 is directed both at the controller and the processor.

6. It should also be clarified that the subject of the administrative proceedings was the possibility of violating the provisions on the protection of personal data in the form of a breach of Article 32(1) and (2) of Regulation 2016/679, and not the Company's liability for the occurrence of a personal data breach. The occurrence of a personal data breach, which was reported to the President of the UODO, constituted a basis for initiating explanatory proceedings against the Company due to doubts regarding the provision of an appropriate level of security for the processed personal data. Furthermore, for broader clarification, it should be noted that the President of the UODO is entitled to determine a violation of the provisions on the protection of personal data concerning the security of that data, even if a personal data breach does not occur. This is confirmed by the ruling of the Supreme Administrative

Court dated February 9, 2023, case file III OSK 3945/21, in which the Court indicated that "the administrative sanction applies to the controller not for the fact that a personal data breach occurred in its organization, but for failing to ensure an adequate standard of security for the processed personal data (...)".

7. During the ongoing proceedings, the Company repeatedly explained that the breach does not pose a risk of infringing the rights or freedoms of individuals, as there was no breach of the confidentiality attribute of the data, indicating, among other things, that "the reported incident was of an incidental nature due to the lack of risk of infringing the rights or freedoms of individuals. Based on the information obtained by the Company, the personal data stored on the servers that were burned in a fire were irretrievably lost, thus excluding the possibility of their unlawful use." This administrative proceeding, which should be emphasized again, does not relate to S7Health's liability for a personal data breach, but rather to the assessment of whether the Company provided appropriate security for the processed data in relation to the breach of the availability attribute of the data, and not the attribute of their confidentiality.

8. Taking into account, in particular, the broad scope... of risk associated with data processing was acceptable, did not conduct an objective assessment, which is a requirement under the aforementioned regulation.

In light of the above, it should be noted that one of the legal bases for the protection of personal data introduced by Regulation 2016/679 is the obligation to ensure the security of processed data, as specified in Article 32(1) of Regulation 2016/679. This provision introduces a risk-based approach, simultaneously indicating the criteria based on which the data controller or processor should select appropriate technical and organizational measures to ensure a level of security corresponding to that risk. In addition to the risk of infringement of the rights or freedoms of natural persons, which is assessed collectively based on the likelihood of occurrence and the severity of the threat, the state of technical knowledge, the cost of implementation, and the nature, scope, context, and purposes of processing must also be taken into account.

In the factual circumstances of the case at hand, the risk pertained to the threat of loss of personal data stored on a server as a result of a fire. It was established that due to the destruction caused by the fire of the servers on which the Company stored personal data, this data was irretrievably lost.

In relation to the above threat, in order to counteract the potential consequences of a personal data breach and to prevent the infringement of the availability attribute of personal data stored on the server, the Company, in accordance with the aforementioned provision of Regulation 2016/679, was obliged to implement appropriate safeguards. The determination of these safeguards should have occurred as a result of a risk analysis conducted after the proper identification of threats to personal data processed in the XXX system, which the Company, it must be emphasized again, did not do.

Consequently, when conducting a risk analysis, the Company should have, in accordance with Article 32(2) of Regulation 2016/679, taken into account the risk associated with processing, arising from accidental or unlawful destruction or loss of data and, based on the criteria specified in Article 32(1) of Regulation 2016/679, including the nature and purpose(s) of personal data processing, determined and implemented appropriate technical and organizational measures aimed at adequately securing the data to ensure its protection, including, as stated in Article 32(1)(b) and (c) of Regulation 2016/679, ensuring the ability to maintain the confidentiality, integrity, availability, and resilience of processing systems and services, as well as the ability to restore the availability of personal data and access to it quickly in the event of a physical or technical incident, such as in the case of a fire.

However, the Company did not specify or implement such security measures in the risk analysis conducted prior to the occurrence of the personal data breach, which constitutes a violation of Articles 32(1)(b) and (c) and Article 32(2) of Regulation 2016/679.

Some security measures were specified in the Security Policy, in which the Company provided for the creation of backups, as well as in the data processing agreement signed with O., where it assumed

responsibility for creating backups necessary to secure personal data. Despite the provisions contained in these documents, S7Health did not implement such security measures.

It should also be noted that the risk analysis aimed at selecting appropriate technical and organizational measures in relation to the risk was not conducted by S7Health in an objective manner, and as explained in Recital 76 of Regulation 2016/679, "the likelihood and severity of the risk of infringement of the rights or freedoms of the data subject should be determined by reference to the nature, scope, context, and purposes of the data processing. The risk should be assessed based on an objective evaluation, within which it is determined whether the processing operations involve risk or high risk." In assessing whether the level of risk associated with data processing was acceptable, the Company did not conduct an objective assessment, which is a requirement under the aforementioned regulation.

****Security Concerns****

The security measures are appropriate; however, the Company did not properly consider the risks associated with processing, particularly those arising from accidental or unlawful destruction or loss of personal data. First and foremost, it should be noted that the President of the UODO's reservations regarding the reliability and objectivity of the risk analysis are related to the lack of presentation by the Company of a complete methodology for conducting the risk analysis, despite a request made by the President of the UODO in this regard. The risk analysis submitted by the Company, along with the methodology for its execution, is incomplete, particularly due to the absence of a risk matrix, and the lack of response from S7Health to the President of the UODO's questions, including those regarding the values substituted in the formula for calculating acceptable risk, effectively prevents its reverse reconstruction for verification purposes.

The above indicates a lack of basis for the Company to accept the final assessment, which would allow it to conclude that the risk is at an acceptable level, and consequently, to consider that the Company was exempt from applying any security measures related to the availability attribute of personal data. It should be noted that the mere fact of establishing that processing operations involve a risk of infringement of the rights or freedoms of individuals necessitates the appropriate application of security measures referred to in Article 32(1)(a)-(d) of Regulation 2016/679. The final risk value established based on the risk analysis determines the standard level of appropriate security measures. Thus, the Company, having determined that there is a risk associated with the operations, even mistakenly assuming that it is acceptable, was not entitled to waive any security measures (which it effectively did) aimed at ensuring the ability to continuously guarantee confidentiality, integrity, availability, and resilience of processing systems and services, as well as the ability to quickly restore the availability of personal data and access to it in the event of a physical or technical incident.

Furthermore, the President of the UODO's reservations regarding the conducted risk analysis concern: the weight of the risk of infringement of the rights or freedoms of individuals whose data is involved; the context of processing – within which the Company did not establish vulnerabilities for specific threats and made an unfounded assessment of the criteria related to the applied security measures, which, as circumstances incorrectly established or not established at all, collectively influenced the incorrect assessment of probability.

In light of the above, it should be clarified that the weight of the risk of infringement of the rights or freedoms of individuals was related by the Company to the consequences of a potential materialization of a threat affecting the rights and freedoms of individuals due to the loss of data availability. According to the risk analysis methodology, S7Health indicated that such an event would have a "moderate impact" on "the impact on the rights or freedoms of individuals whose data is concerned," rating it as 3 on a scale from 1 to 5. In establishing it at this level, it overlooked that the infringement of the availability attribute of personal data processed in system XXX directly limits the rights or freedoms of individuals by preventing them from exercising their rights, including access to personal data that the Company was obliged to store, or may hinder or prevent the provision of medical services. Thus, the Company, according to its own methodology, should have justified in the criterion "identifying consequences," relating to the weight of the infringement, that the event causes a "direct infringement

of the rights or freedoms of individuals whose data is concerned," and consequently, the point value for assessing the impact on the rights or freedoms of individuals whose data is concerned should be rated as 1 on a scale from 1 to 5, which corresponds to the above justification according to the adopted methodology (the Company adopted the following point values for assessing the impact on the rights or freedoms of individuals whose data is concerned: 5 – no impact, 4 – slight impact, 3 – moderate impact, 2 – significant impact, 1 – direct infringement of the rights or freedoms of individuals whose data is concerned). Additionally, the Company related the consequences of the infringement of the availability attribute to such circumstances as possible financial and reputational effects of the infringements. Thus, in assessing the consequences of the infringement of personal data protection, 2 out of 3 circumstances that should be evaluated according to the adopted methodology relate to the consequences for the Company, not for the individuals whose data is concerned. Therefore, it should be emphasized that the consequences for the Company resulting from the infringement of the availability attribute of data should not be included in the conducted risk analysis if they would lead to a reduction of risk, and consequently, for example, the abandonment of the application of a security measure or a reduction in its standard. An approach that places greater weight on assessing the consequences for the administrator rather than for the individuals whose data is concerned is not consistent with the principle of fair data processing and the approach aimed at ensuring the best possible protection of personal data. The administrator, when deciding to process data, cannot prioritize its interests over the protection of personal data. Furthermore, the indication that the consequences of the event will have a moderate impact on finances does not correspond with the assessment of the value of the asset, according to which the servers (which were burned) are used for processing data in a process of crucial or medium importance for achieving business objectives. It should also be noted that the Company, in assessing the impact on reputation, considered that the infringement of the availability attribute of data would result in "an increased number of complaints, requests, letters, and phone calls to the organization," and thus actions directly related to the infringement of the rights or freedoms of individuals, which only confirms that the criterion of impact on rights...

The freedom of individuals was underestimated. The President of the UODO also raises concerns about the lack of grounds for assigning the highest positive rating in the conducted risk analysis for such criteria as "Identifying safeguards" – "Technical safeguards"; "Identifying safeguards" – "Organizational safeguards"; "Assessment of the effectiveness of safeguards" – "Effectiveness of technical safeguards (justification)"; "Assessment of the effectiveness of safeguards" – "Effectiveness of organizational safeguards (justification)", based on statements that the Company was unable to justify, such as "modern solutions with security certifications are used for safeguards"; "organizational safeguards are implemented and subject to periodic, independent reviews"; "safeguards are tested, have been assessed as effective, and no irregularities were detected (with respect to technical and organizational safeguards)", particularly in light of the lack of application of a fundamental measure for safeguarding against data availability loss in the form of performing backups (as indicated, as mentioned above, in the Security Policy and in the personal data processing entrustment agreement concluded with O.). Furthermore, the Company did not provide an answer regarding the information and circumstances on which it based the criterion "identifying vulnerabilities" to conclude "no vulnerability of the resource to the occurrence of a threat". It should be noted that S7Health, despite the President of the UODO's request to specify in detail the specific information on which it based the aforementioned assumptions (not only with respect to the criterion "identifying vulnerabilities"), did not present such information. It only briefly referred to the website of the processing entity (O.), stating that "the Company adopted the conclusions in the criteria listed in points a) - e) above based on information provided by the entity providing server space leasing services [https://\(...\)](https://(...)) (date of access to the website: January 15, 2023)."

The above, in light of the accountability principle expressed in Article 5(2) of Regulation 2016/679, justifies the conclusion that the indicated assumptions were unfounded. Due to the failure to fulfill the obligation to demonstrate (at the request of the President of the UODO) on the basis of what information or circumstances the Company adopted the presented assumptions in the risk analysis, it

should be considered that they were adopted in a completely arbitrary manner, as copied from the risk analysis methodology (since such a description is found there), without verifying them in relation to the processing operations of personal data, in the context of which a breach of personal data protection occurred, which consequently indicates a lack of reliability and the arbitrary nature of the assessment made.

In the conducted risk analysis, the Company identified threats such as: physical destruction, loss of service, and technical failures, information security breaches, unauthorized actions, security function breaches, and assessed the probability of their occurrence at the lowest possible value on the adopted scale, according to its methodology, justifying that the occurrence of these events is unlikely since they did not occur in the last three years. However, it should be emphasized that relating the degree of probability solely to whether an event occurred in the past is not a correct approach. The Company should assess the probability based on internal and external circumstances concerning, in particular, the context of data processing in its organization, and thus the probability should be related not only to experience (the occurrence or non-occurrence of specific events in the past) but also to existing safeguards and their effectiveness, which in this case were arbitrarily assessed, and above all to vulnerabilities, which in this case were not established by the Company at all. Additionally, the adopted period of "the last three years" is completely arbitrary and unjustified, especially since the significance of the resource involved in the breach of personal data protection was assessed by the Company at the highest level on the adopted scale.

As previously indicated, the Company assessed that the servers that were burned and used for processing personal data in the XXX system constitute a resource used by S7Health for processing data in a process of key or medium importance for achieving business objectives. Furthermore, it should also be reiterated that in the personal data processing entrustment agreement concluded with O. (which concerned the processing of data on the servers that were burned), there was a provision stating that the termination or expiration of the service for any reason, as well as certain operations of updating or reinstalling services, result in the automatic and irreversible deletion of all content (including information, data, files, systems, applications, websites, and other elements) that is duplicated, stored, installed, or otherwise used by S7Health within the services. Thus, the resource, so crucial for the Company's operations, was burdened with a vulnerability that could result in the loss of data availability, of which the Company was informed, and for which it did not foresee any security measures in the conducted risk analysis, not even those indicated in this agreement, such as performing backups. Therefore, it should be recognized that the Company was aware of the threats that could result in the loss of data availability and the significance of the threat to personal data processed in the XXX system, as well as the necessity to implement security measures capable of continuously ensuring the confidentiality, integrity, availability, and resilience of systems and services. processing and capable of quickly restoring the availability of personal data and access to it in the event of a physical or technical incident, which has been defined by S7Health in the Security Policy and the data processing entrustment agreement concluded with O. as the creation of backup copies. Actions aimed at ensuring continuity of access for authorized users, regular execution and testing of backup copies, in accordance with the established backup policy, are exemplary security elements indicated, among others, by the standard PN-EN ISO/IEC 27001:2017-06 (in force at the time of the determination of the personal data breach).

As stated in Article 32(1) of Regulation 2016/679, one of the factors to be considered when selecting appropriate technical and organizational measures is the state of technical knowledge, which should be assessed taking into account market conditions, particularly the availability and market acceptability of a given technical solution. Guidelines specifying this matter are provided by applicable standards and norms, particularly ISO standards, which are also subject to continuous reviews and changes conditioned by technological progress.

PN-EN ISO/IEC 27002:2017-06 recommended regular execution and testing of backup copies of information, software, and system images in accordance with the established backup policy. When developing a backup plan, it is recommended, among other things, to store backup copies in a

different location, at a distance that allows avoiding damage caused by a disaster affecting the primary center. However, despite the above circumstances, the Company did not implement such a security measure before the occurrence of the personal data breach; it only began to perform backups after the breach occurred, as a security measure aimed at reducing the likelihood of a future personal data breach.

The result of failing to specify adequate security measures in the risk analysis to ensure compliance with the requirements of Article 32(1)(b) and (c) of Regulation 2016/679 (and consequently their non-implementation) was the materialization of a threat in the form of the destruction of servers on which the data was stored, "without the possibility of restoring the lost data."

Thus, it cannot be considered that the Company, taking into account the state of technical knowledge, the cost of implementation, and the nature, scope, context, and above all the purposes of processing and the risk of infringement of the rights or freedoms of individuals with varying probabilities of occurrence and severity of the threat, implemented technical and organizational measures to ensure a level of security commensurate with that risk, including, among other things, the ability to continuously ensure the availability and resilience of processing systems and services and the ability to quickly restore the availability of personal data and access to it in the event of a physical and technical incident. Furthermore, it cannot be considered that the Company, when assessing whether the level of security is appropriate, correctly took into account, in particular, the risks associated with processing, resulting from accidental or unlawful destruction or loss of personal data transmitted, stored, or otherwise processed, which constitutes a violation of Article 32(1)(b) and (d) and Article 32(2) of Regulation 2016/679.

As indicated by the Provincial Administrative Court in Warsaw in the justification of the judgment of August 26, 2020, case no. II SA/Wa 2826/19, "This provision [Article 32 of Regulation 2016/679] does not require the data controller to implement any technical and organizational measures that are to constitute measures for the protection of personal data, but requires the implementation of adequate measures. Such adequacy should be assessed in terms of the manner and purpose for which personal data is processed, but the risk associated with the processing of that personal data should also be taken into account, which risk may be characterized by varying degrees." Additionally, "The adopted measures must be effective; in specific cases, some measures will have to mitigate low risk, while others must mitigate high risk; however, it is important that all measures (as well as each one individually) are adequate and proportional to the degree of risk."

It should be noted that Regulation 2016/679 has abandoned lists of security requirements imposed by the legislator in favor of self-selection of safeguards based on a threat analysis. Data controllers are not indicated specific measures and procedures regarding security. The controller must independently conduct a detailed analysis of the data processing processes and assess the risk, and then apply such measures and procedures that will be adequate to the estimated risk.

As indicated by the Provincial Administrative Court in Warsaw in the judgment of August 26, 2020, case no. II SA/Wa 2826/19, "(...) technical and organizational activities are the responsibility of the data controller, but they cannot be selected in a completely free and voluntary manner, without taking into account the degree of risk and the nature of the protected personal data."

In summary, the Company, when conducting a risk analysis, should, in accordance with Article 32(2) of Regulation 2016/679, take into account the risks associated with processing, resulting from accidental or unlawful destruction or loss of data, and based on the elements from Article 32(1) of Regulation 2016/679, determine, among other things, that the failure to achieve the purpose of processing or its achievement, but after some time, due to the loss of availability of data caused, for example, by a fire, or the occurrence of circumstances described in the entrustment agreement.

data processing contained with O., which may result in the cessation of services by this entity, may cause difficulties in the provision of medical services for the Company's clients, and in the case of the obligation to retain data, may prevent the realization of rights for the individuals concerned, which undoubtedly affects the assessment that the processing of personal data for these purposes was

associated with the possibility of a risk of infringement of the rights or freedoms of the individuals concerned – and in connection with this circumstance, appropriate technical and organizational measures should be applied to ensure the appropriate security of the availability of personal data, including as provided in Article 32(1)(b) and (c) – the ability to ensure the ongoing confidentiality, integrity, availability, and resilience of processing systems and services, as well as the ability to restore the availability of personal data and access to it quickly in the event of a physical or technical incident. However, the Company did not implement such security measures prior to the occurrence of the personal data breach, and in the risk analysis conducted to determine adequate technical and organizational measures aimed at ensuring appropriate security for the processing of personal data, it did not take into account the purposes of processing, and the analysis itself was conducted in a grossly improper manner, particularly concerning criteria such as the severity of the risk of infringement of the rights or freedoms of natural persons and the context of processing, including the failure to determine vulnerabilities and specific threats and an arbitrary assessment of the effectiveness of safeguards and their identification, which also affected the probability that was not correctly established. The above constitutes a violation by the Company of Article 32(1) and Article 32(2) of Regulation 2016/679.

It should be noted that as established in the factual state, on March 9, 2021, that is, on the day preceding the occurrence of the personal data breach, S7Health submitted an update of the client list (individuals whose data are concerned) to P. Thus, as explained by the Company, it ensured that individuals whose data are concerned had access to the service provided by P., despite the ongoing failure, and ensured this access also in the following days, and therefore did not allow for a break in access to previously sold services for its clients. In light of the above, it should be clarified that the fact that in the month in which the server was destroyed, personal data was transferred to the medical operator is irrelevant for the assessment of whether the Company implemented adequate technical and organizational measures aimed at ensuring the security of the processed personal data, as this circumstance did not arise from the application of any safeguard. Personal data was transferred on March 9, 2021, and the server room was burned down on March 10, 2021; thus, if the fire had occurred a few days earlier, the Company would not have been able to transfer the collected data. However, the subject of the administrative proceedings is the possibility of a violation by S7Health of Article 32(1) and (2) of Regulation 2016/679, and as already explained, the responsibility of the Administrator is assessed in the context of the failure to ensure an appropriate level of security for the processed personal data, and not the occurrence of a personal data breach. The proceedings have shown that the Company did not ensure appropriate security for the personal data of individuals whose data were processed in the XXX system, exposing these individuals, among other things, to the lack of possibility or difficulties in realizing medical services and exercising rights granted to them, among others, under Regulation 2016/679. Moreover, the confirmation of the violation of Article 32(1) and (2) of Regulation 2016/679 is precisely the occurrence of a personal data breach, where as a result of the materialization of the threat, the Company irretrievably lost a database containing personal data of approximately 14,000 individuals, preventing these individuals from exercising control over their personal data and resulting in a real loss of the ability to exercise their rights or freedoms.

At this point, it is necessary to refer to the Company's request from the letter dated March 29, 2022, for the evidence of the "Policy (...)" – regarding the fact of developing, implementing, and adhering to appropriate personal data protection procedures.

As indicated in the Security Policy, which is Annex 1 to the Company's letter of March 29, 2022, this document aimed to define the technical and organizational measures applicable in S7Health Sp. z o.o., which should be considered necessary for compliance with the law, reliability and transparency, correctness, integrity, confidentiality, and accountability of personal data processing in the face of threats against which personal data must be protected (§ (...) para. (...) of the Policy). The Security Policy was developed to ensure standards of personal data security in S7Health, with particular emphasis on their compliance with legal regulations (§ (...) para. (...) of the Policy). According to § (...) para. (...), the Policy describes the technical and organizational safeguards implemented to protect personal data and constitutes the fundamental document for personal data protection within S7Health.

The Policy applies to all operations related to the processing of personal data, regardless of the form and manner of processing and who the data are processed for. As stated in § (...) para. (...) points (...) and (...) – ensuring data security consists of guaranteeing the availability of data, ensuring access to data for individuals whose data are concerned, realization of individual rights, and enabling individuals whose data the Administrator processes to exercise their rights and realize these rights. Furthermore, according to § (...) para. (...) of the Policy, to ensure the security of personal data in S7Health, protective mechanisms were introduced in the form of physical safeguards, hardware measures, ****Organizational Procedures and System Software****

Protective mechanisms are implemented appropriately to the processing activities, taking into account the nature, scope, context, purposes of processing, and the risk of infringement of rights or freedoms of natural persons with varying probabilities and severity of threat, as well as the state of technical knowledge and costs of implementation. The selection of appropriate protective mechanisms in relation to processing activities is carried out primarily based on a risk analysis of personal data breaches, with risk assessment conducted no less than once a year. Furthermore, in accordance with § (...) para. (...) of the Policy, personal data is processed by the Administrator in a manner that ensures their appropriate security, including protection against accidental loss, destruction, or damage, using appropriate technical or organizational measures. Meanwhile, § (...) of the security policy refers to the rights of the data subjects and the principles of their realization, including the right to access data, obtain copies of it, and rectify it.

Based on the above Security Policy, the supervisory authority established that it was developed; however, it had no grounds to assume that the provisions of this document were implemented and that the Company complied with "appropriate personal data protection procedures," including that the development of this policy could not constitute fulfillment of the obligation specified in Article 32 para. 1 and 2 of Regulation 2016/679. The security policy does not specifically address the means of ensuring the availability of personal data, referring instead to the necessity of conducting a risk analysis and, based on it, determining appropriate technical and organizational measures corresponding to Article 32 para. 1 of Regulation 2016/679, directly indicating the elements that needed to be considered to determine this risk, including the purpose of processing personal data. As detailed in this administrative decision, these elements were not taken into account, and consequently, the Company did not implement technical and organizational measures aimed at ensuring the security of processed data commensurate with the risk.

Referring to the request of S7Health to conduct evidence from the "Agreement (...)" – regarding the fact of entrusting the processing of personal data in O., the President of the UODO established the fact of entrustment, which is confirmed in point 2 of the factual description. At the same time, it should be reiterated that both documents provided for the obligation and tasks in the form of performing backups, which, however, were not created by the Company until the occurrence of the personal data breach.

At this point, it is also necessary to refer to the Company's request from the aforementioned letter "to dismiss the proceedings as unnecessary in its entirety in accordance with Article 105 § 1 of the Code of Administrative Procedure, due to the fact that the notification had the character of an incident due to the lack of risk of infringement of the rights or freedoms of natural persons. Based on the information obtained by the Company, the personal data recorded on the servers that were burned as a result of the fire were irretrievably lost, thus excluding the possibility of their unlawful use." It should be noted that the justification for the aforementioned request of the Company refers to the lack of risk of infringement of the rights or freedoms of natural persons in the case of a breach of the confidentiality of their personal data, while the subject of these proceedings was a breach of the provisions of Regulation 2016/679 due to the failure of S7Health to ensure appropriate measures protecting against the loss of availability of personal data. Thus, the Company's request is obviously unfounded.

Based on Article 58 para. 2 lit. i) of Regulation 2016/679, each supervisory authority has the power to impose, in addition to or instead of other corrective measures provided for in Article 58 para. 2 lit. a) - h) and lit. j) of this regulation, an administrative fine under Article 83 of Regulation 2016/679, depending on the circumstances of the specific case. Considering the factual findings, the President of

the Personal Data Protection Office, exercising the powers granted to him under the aforementioned provision of Regulation 2016/679, stated that in the case at hand, there were grounds justifying the imposition of an administrative fine on S7Health.

According to Article 83 para. 4 lit. a) of Regulation 2016/679, violations of the provisions shaping the obligations of the controller and the processor, referred to in Articles 8, 11, 25-39, and 42 and 43, are subject, according to para. 2, to an administrative fine of up to 10,000,000 EUR, and in the case of an enterprise – up to 2% of its total annual worldwide turnover from the previous financial year, with the higher amount applying. In deciding to impose an administrative fine, the President of the UODO – in accordance with the provisions of Article 83 para. 2 lit. a) - k) of Regulation 2016/679 – took into account the following circumstances of the case, which necessitated the application of this type of sanction in this case and which had a burdening effect on the amount of the imposed administrative fine:

1. The nature, gravity, and duration of the infringement, taking into account the nature, scope, or purpose of the processing, the number of affected individuals whose data were concerned, and the extent of the damage suffered by them (Article 83 para. 2 lit. a) of Regulation 2016/679). After conducting the administrative proceedings, the President of the UODO found a violation of the Company's obligations arising from the provisions of Article 32 para. 1 and 2 of Regulation 2016/679, the category of which, according to their nature, was defined in Article 83 para. 4 lit. a) of Regulation 2016/679. Therefore, the nature of the violation of personal data protection regulations is serious, classified as

****Category of regulations, the violation of which is subject to an administrative monetary penalty of up to 10,000,000 EUR.****

It should be emphasized that the Company violated the provisions of Regulation 2016/679, which introduce fundamental obligations regarding the application of appropriate security measures to ensure the protection of processed personal data, including ensuring the ability to maintain continuous availability of data and the rapid restoration of availability of personal data and access to it in the event of a physical incident, such as, for example, a fire in the servers used for their processing. As a result, it was unable to restore this data – as the Company itself indicated, “the personal data stored on the servers that were burned in the fire were lost irretrievably.” This clearly indicates the serious nature of the violation.

The number of affected individuals is not small, encompassing approximately 14,000 people, with the number of individuals whose documents containing data – including invoices and referrals for occupational medicine of employees of companies cooperating with S7Health – estimated by the Company to be 500 individuals. The Company processed the data of these individuals, among other purposes, for archiving, which was its legal obligation. Due to the irretrievable destruction of data, both the Company and the individuals whose data is concerned lost access to it, which potentially hinders the realization of the rights or freedoms of these individuals, such as access to personal data, its correction, rectification, or the preparation of copies, in accordance with Articles 15 and 16 of Regulation 2016/679. The failure to ensure the possibility for the individuals concerned to exercise the above rights, while the Company had a legal obligation to retain data and the large number of these individuals, indicates the significant weight of the violation.

Individuals whose personal data is affected by the violation lost the ability to access their personal data and thus suffered harm in the form of a violation of their right to data protection (Article 41, paragraph 1 of the Constitution of the Republic of Poland). The above may also potentially expose these individuals to material harm.

Also, the duration of the violation, i.e., from May 25, 2018 (the date of the commencement of the application of Regulation 2016/679 – taking into account the period of entrusting data processing and storing it on the servers that were burned) to March 10, 2021 (the date of the violation of personal data protection consisting of the destruction of the server room due to fire), during which the Company did not ensure that processing was carried out in a manner that ensured appropriate security of personal

data, including protection against accidental loss, destruction, using appropriate technical or organizational measures, was significant. Moreover, the duration of the violation concerning individuals identified by the Company as “new and existing users, individuals registering in the XXX system” was also significant, as it covered the period from March 1, 2020, to March 10, 2021.

Furthermore, the Company processed the personal data of individuals whose data is concerned for the purpose of providing medical services, without ensuring an appropriate level of security for this data, thereby exposing these individuals to the possibility of failing to provide the medical service or hindering it, which could constitute a high risk of violation of the rights or freedoms of natural persons.

Thus, individuals whose data was processed in the XXX system from May 25, 2018, to March 10, 2021, were exposed to the possibility of a risk of violation of their rights or freedoms, in the form of the inability or lack of immediate realization of the medical service in the event of data or system loss and difficulties in settling the service.

****2. Intentional nature of the violation (Article 83, paragraph 2, letter b of Regulation 2016/679). **** The Company was aware of how it should process personal data stored on the servers that were burned to ensure appropriate security for them, including protection against accidental loss, destruction, or damage, using appropriate technical and organizational measures, and thus how to comply with the principle of “integrity and confidentiality” expressed in Article 5, paragraph 1, letter f) of Regulation 2016/679 (this circumstance is confirmed by the provisions of the Security Policy and the entrustment agreement). At the same time, the above principle is concretized in Article 32, paragraphs 1 and 2 of Regulation 2016/679, according to which the Company, taking into account the criteria contained in the provision, was obliged to implement technical and organizational measures appropriate to the risk, including ensuring the ability to maintain continuous availability and resilience of processing systems and services and the ability to quickly restore availability of personal data and access to it in the event of a physical or technical incident. The Company conducted a risk analysis in a completely arbitrary manner, incorrectly assuming that the risk was at an acceptable level. At the same time, it did not apply the security measures specified by itself in the Security Policy and indicated in the entrustment agreement in the form of performing backups, and took real action only after the occurrence of the personal data breach.

The Company’s actions revealed an awareness of the lack of provision of an appropriate level of security for personal data processed on the servers. Therefore, the Company was aware that during the period from the entrustment of personal data processing to the materialization of the threat, it did not ensure an appropriate level of security for personal data processed on the servers, which would constitute a violation of data protection regulations.

personal data. Thus, it intentionally violated the provisions of Article 32(1) and (2) of Regulation 2016/679. Taking into account the findings in the case subject to the resolution of this decision, it should be stated that the Company – despite being aware – committed negligence resulting in a breach of personal data protection concerning the availability of data. Therefore, this constitutes a significant circumstance that adversely affects the amount of the administrative monetary penalty.

3. The degree of cooperation with the supervisory authority in order to remedy the breach and mitigate its potential negative effects (Article 83(2)(f) of Regulation 2016/679). It should be noted that cooperation with the supervisory authority in order to remedy the breach and mitigate its potential negative effects should, in particular, lead to determining whether the Administrator has the ability, and if so, how to possibly mitigate the negative effects for the individuals concerned, and on the other hand, enable the supervisory authority to assess whether to exercise its corrective powers, with the determination of circumstances aimed at assessing whether, within the framework of the breach of personal data protection, there was a possibility of risk or high risk for the individuals concerned, serving as the foundation for this cooperation.

The cooperation with the supervisory authority was unsatisfactory, and the scale of irregularities significantly influenced the decision regarding the imposition of the administrative monetary penalty and its amount. The above particularly refers to circumstances such as the failure to provide or evasive

responses to the questions posed, or the lack of presentation of evidence requested by the President of the UODO. The scale of this lack of cooperation and its manner even justifies the assumption that these were deliberate actions by the Company aimed at hindering the conduct of administrative proceedings regarding the determination of circumstances significant for resolving the case, and thus remedying the breach and its potential consequences in the form of: determining the purposes of processing and their legal basis; the number of individuals affected by the breach; possible consequences of the breach of personal data protection for the individuals concerned; processing operations related to which the breach of personal data protection occurred; the correctness of conducting a risk analysis aimed at determining appropriate technical and organizational measures; determining the risk of infringement of the rights or freedoms of natural persons related to data processing operations and the possibility of the occurrence of risks to the rights or freedoms of natural persons in connection with the breach of personal data protection. Furthermore, the Company persistently provided terse and evasive answers or did not respond at all, consequently forcing the President of the UODO to repeatedly request responses to the same questions.

The explanations provided by the Company not only did not assist in determining the possible consequences of the breach of personal data protection for the individuals concerned, but rather hindered it; it is also significant that the Company completely omitted the purpose of processing personal data in the form of the obligation to archive them, which directly indicates possible consequences in the form of lack of access to their personal data.

Additionally, the President of the UODO, in a letter dated December 27, 2022, again requested the Company to send an analysis of the risk and the impact of the loss of data availability on the rights and freedoms of the individuals concerned, clearly explaining, quote: "considering that the President of the UODO, in a letter dated February 17, 2022, asked S7 Health whether the Administrator conducted a risk analysis and the impact of the lack of availability of data processed using IT systems covered by the breach on the rights and freedoms of the individuals concerned," as a result of which the Company, in a letter dated March 9, 2022, sent "a risk analysis for resources processing personal data," I again request the submission of an analysis of the risk and the impact of the lack of availability of data processed using IT systems covered by the breach on the rights or freedoms of the individuals concerned." In response, S7 Health did not present such an analysis.

It should be noted that to determine the possible damage related to the severity of the breach, the President of the UODO, in a letter dated November 9, 2022, asked, among other things, questions regarding the realization and the possibility of realizing the rights of the individuals concerned and requested the presentation of evidence confirming the explanations provided. In response, the Company, in a letter dated November 27, 2022, explained that there were no cases in which it could not fulfill or comply with any rights or freedoms of the individuals concerned; the Company never received a request for access to personal data; due to the destruction of documentation containing personal data, the Administrator did not encounter any difficulties in fulfilling a request for access to personal data. In turn, in a letter dated January 16, 2023, the Company explained that it had not recorded any requests, inquiries, complaints, demands, or other communications. However, it should be noted that the Company did not present any evidence confirming the explanations provided, despite being requested to do so by the President of the UODO. In light of the above, the President of the UODO requested the presentation of specific evidence in the form of "sending a register of requests for the realization of the rights of the individuals concerned, and in the absence of such a register, sending a relevant statement from the person responsible for maintaining such a register, regarding the lack of such requests." In response, the Company, in a letter dated January 16, 2023, did not present such a register, nor did it provide a relevant statement. However, it informed that "does not maintain such a register, as no currently applicable legal provision obliges it to do so, nor does it even mention it. There has never been such a need, as such requests have not been submitted to the Company." Meanwhile, the Company, in accordance with § (...) item (...) in connection with § (...) item (...) of the "Policy (...)" has obligated the data protection officer to maintain a "register of requests for the exercise of rights of data subjects." Thus, the Company's response and the lack of

presentation of evidence in the form of a relevant statement from the data protection officer, as requested by the President of the UODO, are unjustified. Additionally, the President of the UODO clarifies that he had no basis to conclude that the Company has a low understanding of its own procedures, as the Company requested to present evidence, among others, from the "Policy (...)" – regarding the fact of developing, implementing, and adhering to appropriate personal data protection procedures, which indeed makes such an assumption unjustified. It should also be noted that the President of the UODO has serious doubts regarding the credibility of the Company's explanations. The President of the UODO's previous practice in such cases, corresponding to the principles of life experience, indicates that in the event of a personal data breach and informing a large number of individuals about this fact, there is a reaction from at least some of the data subjects, in the form of sending at least an email to the administrator. Administrators are often forced to provide a special hotline and appoint temporary teams of employees to handle such reports. Therefore, it is unlikely that among approximately 14,000 individuals notified individually (in electronic form) about the breach of their personal data, not a single person would have reached out for at least additional clarifications, especially since the Company provided them with the opportunity for a return response. Furthermore, regarding the number of individuals affected by the personal data breach, the Company unjustifiably indicated that the breach concerned 500 individuals, without explaining why it adopted that specific number, while the report of the personal data breach clearly indicates that the breach concerned 14,000 individuals, and that many individuals were notified by S7Health about the breach of their personal data. At the same time, the Company did not respond to the President of the UODO's questions or provided false answers regarding the number of individuals affected by the breach, distinguishing between their categories and the scope of data as well as the purposes and legal bases for processing, which questions aimed to establish all circumstances relevant to the case, including, among others, the number of individuals affected by the personal data breach. Based on the above circumstances relating to the degree of cooperation, it should be explained that the President of the UODO could not base the factual state on the explanations of S7Health, considering them inconsistent, chaotic, not corresponding with each other, contradictory to the evidence, or not arising from the evidence. The President of the UODO based the factual findings solely on the explanations of S7Health when they were confirmed by the collected evidence or were logically obvious and took into account the principles of life experience. In this regard, he considered the report of the personal data breach credible, despite S7Health indicating that the person preparing it made an error by using the term "patient" in reference to the Company's client. In the opinion of the President of the UODO, the person filling out the report was entitled to indicate as the category of individuals affected by the personal data breach, patients, as the individuals whose data are concerned were designated as such, among others, in the template agreement for medical care "S7Health (...)" and in the "General (...)" (pages 148, 153). It should be emphasized that the President of the UODO repeatedly requested S7Health to provide evidence confirming the submitted explanations, and such evidence (except for part of the evidence, for which the President of the UODO directly called for presentation, indicating their name), apart from the attachment to the letter dated January 16, 2023 (email correspondence, pages 155-156), was not presented. In deciding to impose an administrative monetary penalty, the President of the UODO took into account the following circumstances of the case, which necessitate the application of this type of sanction in this case and which have a mitigating effect on the amount of the imposed administrative monetary penalty: Actions taken to minimize the damage suffered by the data subjects (Article 83(2)(c) of Regulation 2016/679). On March 22, 2021, after the disclosure of the personal data breach, S7 Health informed the data subjects by sending an email to approximately 14,000 individuals affected by the breach. Additionally, it posted a notice about the breach on its website. It should be noted that in connection with the occurrence of the personal data breach, no circumstances were found that would obligate the Company to notify those individuals about the breach, in accordance with the provisions of Article 34(1) of Regulation 2016/679. Thus, it should be acknowledged that the Company voluntarily informed the data subjects about the breach, while also providing them with the opportunity to provide feedback. Such action certainly deserves approval and was taken into account as a mitigating circumstance. Other circumstances, indicated below, referred to in Article 83(2) of Regulation 2016/679, after assessing their impact on the established breach of the

provisions of Regulation 2016/679 in this case, were considered by the President of the UODO to be neutral in his assessment, meaning they had neither an aggravating nor a mitigating effect on the amount of the imposed administrative monetary penalty. 1. Degree of responsibility of the administrator."

with consideration of the technical and organizational measures implemented by him pursuant to Articles 25 and 32 (Article 83(2)(d) of Regulation 2016/679). In the Guidelines adopted on October 3, 2017, by the Article 29 Working Party on the application and determination of administrative fines for the purposes of Regulation No. 2016/679, it was indicated that - when considering this criterion - "the supervisory authority must answer the question of to what extent the controller, taking into account the nature, purposes, or scope of processing and in light of the obligations imposed on him by the regulation." The President of the UODO stated in this case that the Administrator violated Article 32(1) and (2) of Regulation 2016/679. In his opinion, the administrator bears a high degree of responsibility for failing to implement appropriate technical and organizational measures that would have prevented the breach of personal data protection. It is obvious that in the considered context of the nature, purpose, and scope of personal data processing, the Administrator did not "do everything that could be expected of him"; thus, he did not fulfill the obligations imposed on him by Article 32 of Regulation 2016/679.

In this case, this circumstance constitutes the essence of the breach itself; it is not merely a factor influencing - mitigating or aggravating - its assessment. For this reason, the lack of appropriate technical and organizational measures referred to in Article 32 of Regulation 2016/679 cannot be recognized by the President of the UODO in this case as a circumstance that could additionally influence a stricter assessment of the breach and the imposition of an administrative fine on the Company.

2. Any relevant prior violations by the controller or processor (Article 83(2)(e) of Regulation 2016/679). The President of the UODO did not find any prior violations of personal data protection regulations committed by the Administrator, which means there are no grounds to treat this circumstance as aggravating. It is the responsibility of every controller to comply with the law (including personal data protection), so the absence of prior violations cannot be a mitigating circumstance when imposing sanctions.

3. Categories of personal data affected by the breach (Article 83(2)(g) of Regulation 2016/679). The personal data located on the burned servers did not belong to special categories of personal data referred to in Articles 9 or 10 of Regulation 2016/679, and their scope was as follows: surnames and first names, addresses of residence or stay, PESEL identification numbers, email addresses, phone numbers, and data contained in documents such as invoices and referrals for occupational medicine. At the same time, it should be noted that the breach of personal data protection did not involve a breach of the confidentiality and integrity attributes of personal data, the categories of which particularly influence the determination of the level of risk of infringement of the rights or freedoms of natural persons.

4. The manner in which the supervisory authority became aware of the breach (Article 83(2)(h) of Regulation 2016/679). The President of the UODO identified the breach as a result of a report of a personal data breach made by S7 Health. By making this report, the Company was merely fulfilling its legal obligation, and there are no grounds to consider this circumstance as a mitigating factor. According to the Guidelines on the application and determination of administrative fines for the purposes of Regulation No. 2016/679, WP 253, "The supervisory authority may learn of a breach as a result of proceedings, complaints, articles in the press, anonymous tips, or notifications by the data controller. According to the regulation, the controller is obliged to notify the supervisory authority of a personal data breach. The mere fulfillment of this obligation by the controller cannot be interpreted as a mitigating factor."

5. Compliance with previously applied measures in the same case referred to in Article 58(2) of Regulation 2016/679 (Article 83(2)(i) of Regulation 2016/679). Prior to issuing this decision, the President of the UODO did not apply any measures listed in Article 58(2) of Regulation 2016/679

against the Company in the case under consideration, which means the Company had no obligation to take any actions related to their application, and such actions, assessed by the President of the UODO, could have had an aggravating or mitigating impact on the assessment of the identified breach.

6. The application of approved codes of conduct under Article 40 of Regulation 2016/679 or approved certification mechanisms under Article 42 of Regulation 2016/679 (Article 83(2)(j) of Regulation 2016/679). The Company does not apply approved codes of conduct or approved certification mechanisms referred to in the provisions of Regulation 2016/679. However, their adoption, implementation, and application are not - as stated in the provisions of Regulation 2016/679 - mandatory for controllers and processors, which means that the circumstance of their non-application cannot be interpreted against the Company in this case. On the other hand, the circumstance of adopting and applying such instruments could be taken into account in favor of the Company as measures guaranteeing a higher than standard level of protection for processed personal data.

7. Any other aggravating or mitigating factors applicable to the circumstances of the case, directly or indirectly related to the breach, financial benefits gained, or losses avoided (Article 83(2)(k) of Regulation 2016/679). The President of the UODO, comprehensively considering the case, did not record any other factors than those described above.

****Circumstances that may affect the assessment of the violation and the amount of the imposed administrative monetary penalty.****

Taking into account all the circumstances discussed above, the President of the Personal Data Protection Office has determined that the imposition of an administrative monetary penalty on S7 Health is necessary and justified by the seriousness, nature, and scope of the alleged violations by S7 Health. It should be noted that the application of any other corrective measure provided for in Article 58(2) of Regulation 2016/679, particularly a mere reprimand (Article 58(2)(b)), would not be proportional to the identified irregularities in the processing of personal data and would not guarantee that S7 Health would not commit further negligence in the future.

In accordance with the provisions of Article 103 of the Act of May 10, 2018, on the Protection of Personal Data (Journal of Laws of 2019, item 1781), the amounts expressed in euros referred to in Article 83 of Regulation 2016/679 are calculated in zlotys according to the average euro exchange rate announced by the National Bank of Poland in the exchange rate table on January 28 of each year, and in the event that the National Bank of Poland does not announce the average euro exchange rate on January 28 of a given year - according to the average euro exchange rate announced in the nearest exchange rate table of the National Bank of Poland after that date.

In the opinion of the President of the Personal Data Protection Office, the administrative monetary penalty imposed on S7 Health in the amount of 117,900 PLN (in words: one hundred seventeen thousand nine hundred zlotys), which is equivalent to 25,000 euros (average euro exchange rate from January 30, 2023 - 4.716 PLN), fulfills the functions mentioned in Article 83(1) of Regulation 2016/679 in the established circumstances of this case, i.e., it is effective, proportional, and deterrent in this individual case.

In the opinion of the President of the Personal Data Protection Office, the penalty imposed on the Company is proportional both to the seriousness of the violation and to the size of the Company, which size - measured by its turnover - should be considered inextricably linked to the effectiveness of the penalty and its deterrent nature.

During the proceedings, S7 Health submitted its financial report for 2022, according to which its net sales revenue amounted to 8,458,585.48 PLN (in words: eight million four hundred fifty-eight thousand five hundred eighty-five zlotys 48/100), which is equivalent to 1,793,593.18 euros at the average euro exchange rate from January 30, 2023. The net profit amounted to 1,053,248.35 PLN (in words: one million fifty-three thousand two hundred forty-eight zlotys 35/100), with an average employment of 4 people during the financial year.

Considering the above financial results of S7 Health, it should be stated that the imposed administrative monetary penalty will not be excessively burdensome for it. It should be noted that the amount of the penalty determined by the President of the Personal Data Protection Office - 117,900 PLN - constitutes only 1.39% of its turnover achieved in 2022. At the same time, in the opinion of the President of the Personal Data Protection Office, the penalty at this level will be effective (achieving the goal of punishing the Company for a serious violation with serious consequences) and deterrent for the future.

Regarding the amount of the administrative monetary penalty imposed on S7 Health, the President of the Personal Data Protection Office considered that it is proportional to the violation that occurred - it is worth emphasizing that the amount of the imposed penalty of 117,900 PLN is only 0.25% of the maximum penalty that the President of the Personal Data Protection Office could impose on S7 Health for the violation identified in this case - applying, in accordance with Article 83(4) of Regulation 2016/679, the static maximum penalty (i.e., 10,000,000 euros).

In light of the above, the President of the Personal Data Protection Office further indicates that the administrative monetary penalty imposed on S7 Health particularly meets the criterion of proportionality of the penalty in the sense developed in the case law of the Court of Justice of the European Union (in the context of competition law and in relation to decisions of the European Commission, but having, in the opinion of the President of the Personal Data Protection Office, a more general application): "[...] the principle of proportionality requires that acts issued by the institutions of the Union do not exceed the limits of what is appropriate and necessary to achieve the legitimate objectives pursued by the relevant provisions, whereby where there is a possibility of choosing from a number of appropriate solutions, the least burdensome should be applied, and the resulting disadvantages must not be excessive in relation to the intended objectives [...] (see judgment of December 12, 2012, *Electrabel / Commission*, T-332/09, EU:T:2012:672, para. 279 and the case law cited therein)" (see judgment of October 26, 2017, in case T-704/14 *Marine Harvest ASA v. Commission*, para. 580).

In the opinion of the President of the Personal Data Protection Office, the applied administrative monetary penalty fulfills, in the established circumstances of this case, the functions mentioned in Article 83(1) of Regulation 2016/679, i.e., it will be effective, proportional, and deterrent in this individual case.

According to the President of the Personal Data Protection Office, the penalty imposed on S7 Health will be effective, as it will lead to a situation in which S7 Health will implement such technical and organizational measures that ensure the processed data a level of security corresponding to the risk of infringement of the rights and freedoms of the data subjects and the seriousness of the threats associated with the processes of processing that personal data. The effectiveness of the penalty is therefore equivalent to the guarantee that S7 Health, from the moment of the conclusion of these proceedings, will approach the requirements set by the personal data protection regulations with the utmost diligence.

The applied administrative monetary penalty is also proportional to the identified violation, especially regarding its seriousness, impact, the circle of affected individuals, and the high risk of negative consequences associated with the data processing operations. In the opinion of the President of the Personal Data Protection Office, the imposed

****S7Health Administrative Monetary Penalty****

The administrative monetary penalty imposed on S7Health will not constitute an excessive burden for it. The amount of the penalty has been set at a level that, on one hand, represents an adequate response from the supervisory authority to the degree of violation of the administrator's obligations, and on the other hand, does not lead to a situation where the necessity to pay it would result in negative consequences, in the form of a significant deterioration of the Company's financial situation. According to the President of the Personal Data Protection Office (UODO), S7Health should and is able to bear the consequences of its negligence in the area of data protection; hence, the imposition of

a penalty in the amount of 117,900 PLN (one hundred seventeen thousand nine hundred zlotys) is fully justified.

In the opinion of the President of UODO, the administrative monetary penalty will serve, in these specific circumstances, a repressive function, as it will be a response to S7Health's violation of the provisions of Regulation 2016/679, but also a preventive function, as it will contribute to preventing future violations of S7Health's obligations arising from the personal data protection regulations.

In the opinion of the President of UODO, the monetary penalty applied meets, in the established circumstances of this case, the criteria referred to in Article 83(1) of Regulation 2016/679 due to the seriousness of the identified violations in the context of the fundamental requirements and principles of Regulation 2016/679. The purpose of the imposed penalty is to ensure that S7Health complies with the provisions of Regulation 2016/679 in the future.

In this factual and legal situation, the President of the Personal Data Protection Office has decided as stated in the operative part.

****Print Article****

****Metadata****

Provider: Department of Control and Violations

Information created by: Jan Nowak

2023-11-30

Information entered by: Wioletta Golańska

2023-12-19 14:34:44

Last modified by: Edyta Madziar

2024-05-24 11:07:15